

ANÁLISIS DE SUPERFICIE DE ATAQUE

Informe de exposición externa

ejemplo.com · 192.168.1.10 · 6 activos analizados · 8 hallazgos de seguridad

72

Exposición Alta

Score de exposición / 100

2

CRÍTICOS

2

ALTOS

2

MEDIOS

2

INFORMATIVOS

Activos analizados:

admin@ejemplo.com · ejemplo.com · https://ejemplo.com · ejemplo.com:443 · 192.168.1.10 · staging.ejemplo.com

DISTRIBUCIÓN DE RIESGO



RESUMEN EJECUTIVO

Se ha realizado un análisis de superficie de ataque sobre 2 objetivos: ejemplo.com, 192.168.1.10. El análisis identificó un total de 8 hallazgos de seguridad, de los cuales 2 son críticos, 2 de alta severidad, 2 de severidad media y 2 informativos. El score de exposición calculado es 72/100 — Exposición Alta.

Índice de contenidos

- 1. 1. Hallazgos Críticos
 - 1. 1.1. Puerto 22 (SSH) expuesto con versión vulnerable
 - 2. 1.2. Credenciales filtradas en breach de datos (2023)
- 2. 2. Hallazgos Altos
 - 1. 2.1. Cabeceras HTTP de seguridad ausentes
 - 2. 2.2. Subdominio de staging con panel de administración expuesto
- 3. 3. Hallazgos Medios
 - 1. 3.1. Registros SPF y DMARC incorrectamente configurados
 - 2. 3.2. Certificado SSL próximo a caducar
- 4. 4. Hallazgos Informativos
 - 1. 4.1. Información de registro WHOIS pública
 - 2. 4.2. Tecnologías web detectadas en el servidor
- 5. 5. Plan de acción

1. Hallazgos Críticos

2 hallazgos

Explotación posible o inminente — respuesta inmediata para evitar compromiso total del sistema.

1.1. Puerto 22 (SSH) expuesto con versión vulnerable

CRÍTICO

NMAP

192.168.1.10

CSF · PR · Proteger

CRÍTICO — Explotación posible o inminente. Respuesta inmediata requerida para evitar compromiso total.

El servicio SSH en el puerto 22 responde con OpenSSH 7.2p2, versión afectada por CVE-2016-6515 (denegación de servicio por autenticación de contraseña). La versión detectada no ha recibido parches de seguridad en los últimos 3 años.

Función CSF PR: Proteger — controles preventivos para limitar el impacto

ACCIÓN RECOMENDADA

Actualizar OpenSSH a la versión 9.x. Restringir acceso SSH mediante firewall a IPs autorizadas. Deshabilitar autenticación por contraseña y usar solo clave pública.

192.168.1.10

NMAP

CSF PR

1.2. Credenciales filtradas en breach de datos (2023)

CRÍTICO

INTELX

admin@ejemplo.com

CSF · ID · Identificar

CRÍTICO — Explotación posible o inminente. Respuesta inmediata requerida para evitar compromiso total.

Se han encontrado 3 combinaciones de email+contraseña en texto plano asociadas al dominio ejemplo.com en bases de datos de brechas conocidas. Las credenciales datan de una filtración de 2023 y podrían estar siendo utilizadas en ataques de credential stuffing.

Función CSF ID: Identificar — inventario de activos y comprensión de la exposición

ACCIÓN RECOMENDADA

Forzar reset de contraseñas para todos los usuarios afectados. Activar MFA en todas las cuentas. Revisar logs de acceso de los últimos 6 meses.

admin@ejemplo.com

INTELX

CSF ID

2. Hallazgos Altos 2 hallazgos

Riesgo significativo explotable con recursos moderados — planificar mitigación urgente antes de 72 h.

2.1. Cabeceras HTTP de seguridad ausentes

ALTO

URLSCAN

https://ejemplo.com

CSF · PR · Proteger

ALTO — Riesgo significativo explotable con recursos moderados. Atención prioritaria antes de 72 h.

El servidor web no incluye las siguientes cabeceras de seguridad críticas:

- Content-Security-Policy (CSP)
- Strict-Transport-Security (HSTS)
- X-Frame-Options
- X-Content-Type-Options

Esto facilita ataques XSS, clickjacking y MITM.

Función CSF PR: Proteger — controles preventivos para limitar el impacto

ACCIÓN RECOMENDADA

Configurar las cabeceras de seguridad HTTP en el servidor web. Implementar una política CSP estricta.

https://ejemplo.com

URLSCAN

CSF PR

2.2. Subdominio de staging con panel de administración expuesto

ALTO

SUBFINDER

staging.ejemplo.com

CSF · PR · Proteger

ALTO — Riesgo significativo explotable con recursos moderados. Atención prioritaria antes de 72 h.

El subdominio staging.ejemplo.com resuelve a una IP pública y expone un panel de administración WordPress sin autenticación adicional. El entorno de staging contiene datos reales de clientes.

Función CSF PR: Proteger — controles preventivos para limitar el impacto

ACCIÓN RECOMENDADA

Restringir el acceso al entorno de staging mediante autenticación HTTP básica o VPN.
No usar datos reales en entornos de preproducción.

staging.ejemplo.com

SUBFINDER

CSF PR

3. Hallazgos Medios

2 hallazgos

Amplían la superficie de ataque — incluir en el plan de mejora continua de seguridad.

3.1. Registros SPF y DMARC incorrectamente configurados

MEDIO

DNS

ejemplo.com

CSF · PR · Proteger

MEDIO — Amplía la superficie de ataque. Incluir en el plan de remediación a corto plazo.

El registro SPF incluye la directiva +all, permitiendo que cualquier servidor envíe correo en nombre del dominio. La política DMARC está configurada en p=none, sin aplicar ninguna acción sobre correos que fallen la validación.

Función CSF PR: Proteger — controles preventivos para limitar el impacto

ACCIÓN RECOMENDADA

Cambiar SPF a -all. Configurar DMARC con p=quarantine o p=reject para proteger contra phishing y spoofing.

ejemplo.com

DNS

CSF PR

3.2. Certificado SSL próximo a caducar

MEDIO

NMAP

ejemplo.com:443

CSF · PR · Proteger

MEDIO — Amplía la superficie de ataque. Incluir en el plan de remediación a corto plazo.

El certificado TLS del dominio principal expira en 14 días. Si no se renueva a tiempo, los usuarios recibirán advertencias de seguridad en el navegador y el tráfico HTTPS podría verse interrumpido.

Función CSF PR: Proteger — controles preventivos para limitar el impacto

ACCIÓN RECOMENDADA

Renovar el certificado SSL/TLS antes de la fecha de expiración. Configurar renovación automática con Let's Encrypt o el proveedor actual.

ejemplo.com:443

NMAP

CSF PR

4. Hallazgos Informativos

2 hallazgos

Sin riesgo directo — contextualizan la infraestructura y apoyan hallazgos de mayor severidad.

4.1. Información de registro WHOIS pública

INFORMATIVO

WHOIS ejemplo.com CSF · GV · Gobernar

INFORMATIVO — Sin riesgo directo. Contextualiza la infraestructura y puede apoyar hallazgos de mayor severidad.

Los datos de registro del dominio (nombre, email, teléfono y dirección) son accesibles públicamente a través de WHOIS. Esta información puede ser utilizada para ataques de ingeniería social o phishing dirigido.

Función CSF GV: Gobernar — políticas y gestión del riesgo cibernético

ACCIÓN RECOMENDADA
Activar la protección de privacidad WHOIS (WHOIS Privacy Protection) ofrecida por el registrador.

ejemplo.com WHOIS CSF GV

4.2. Tecnologías web detectadas en el servidor

INFORMATIVO

URLSCAN https://ejemplo.com CSF · ID · Identificar

INFORMATIVO — Sin riesgo directo. Contextualiza la infraestructura y puede apoyar hallazgos de mayor severidad.

Se han identificado las siguientes tecnologías: WordPress 6.4.2, PHP 8.1, Apache 2.4.57, jQuery 3.6.0. La exposición de versiones específicas facilita la búsqueda de vulnerabilidades conocidas para esas versiones.

Función CSF ID: Identificar — inventario de activos y comprensión de la exposición

ACCIÓN RECOMENDADA
Ocultar cabeceras de servidor (X-Powered-By, Server). Mantener todas las tecnologías actualizadas.

https://ejemplo.com URLSCAN CSF ID

5. Plan de acción

8 acciones priorizadas por severidad. Cada línea indica los activos afectados y la medida concreta a aplicar.

1	192.168.1.10 · NMAP	CRÍTICO	Actualizar OpenSSH a la versión 9.x. Restringir acceso SSH mediante firewall a IPs autorizadas. Deshabilitar autenticación por contraseña y usar solo clave pública.
2	admin@ejemplo.com · INTELX	CRÍTICO	Forzar reset de contraseñas para todos los usuarios afectados. Activar MFA en todas las cuentas. Revisar logs de acceso de los últimos 6 meses.
3	https://ejemplo.com · URLSCAN	ALTO	Configurar las cabeceras de seguridad HTTP en el servidor web. Implementar una política CSP estricta.
4	staging.ejemplo.com · SUBFINDER	ALTO	Restringir el acceso al entorno de staging mediante autenticación HTTP básica o VPN. No usar datos reales en entornos de preproducción.
5	ejemplo.com · DNS	MEDIO	Cambiar SPF a -all. Configurar DMARC con p=quarantine o p=reject para proteger contra phishing y spoofing.
6	ejemplo.com:443 · NMAP	MEDIO	Renovar el certificado SSL/TLS antes de la fecha de expiración. Configurar renovación automática con Let's Encrypt o el proveedor actual.
7	ejemplo.com · WHOIS	INFORMATIVO	Activar la protección de privacidad WHOIS (WHOIS Privacy Protection) ofrecida por el registrador.
8	https://ejemplo.com · URLSCAN	INFORMATIVO	

Ocultar cabeceras de servidor (X-Powered-By, Server). Mantener todas las tecnologías actualizadas.